Incident Response Report

Scenario:

Ms. Wilde, pleased with your performance on the malware case, has decided to give you another incident. The overworked, underpaid, and understaffed IT administrator of a small business has contacted Palindrome to analyze some network traffic around the time of an abnormal spike in traffic. Your mission, should you choose to accept it - and Ms. Wilde has decided that you do - is to analyze the provided packet capture and report on the activity found therein which may. To aid in your goals, the administrator has provided a few details about the network from which the capture originated. There are four computers on the network. The IT administrator admin box is an Ubuntu server. There are also DHCP and web servers and the Admin is the only individual within the company with authorization for access to those servers. There are two other employees, Bob Smith, a new hire and recent college graduate, who uses a workstation with network access running Windows XP, and Sarah, a developer who uses a workstation with a standard installation of Ubuntu also with network access. Both Bob and Sarah are authorized to have access to their own workstation and no others.

- Used the Lateral_Movement_Investigation.pcap file.

Section 1: Common Network Forensics

1. What is the network address and subnet mask?

- Subnet mask: 255.255.255.0
- Network address: 192.168.100.0

2. For each computer:

a. **What is the IP of the computer?**
b. **What OS is it running?**
c. **What is the MAC address?**
    - 192.168.100.26 [xp]: Bob's Windows XP workstation.
        - **MAC:** 00:0C:29:94:F2:0D
    - 192.168.100.27 [Ubuntu]: Sarah's Ubuntu workstation.
        - **MAC:** 00:0C:29:81:09:11
    - 192.168.100.28 [www] (Linux): Admin's Ubuntu Server (because of www).
        - **MAC:** 00:0C:29:15:09:D5
    - 192.168.100.5 (Windows): Hosts DHCP (and FTP Server)
        - **MAC:** 00:0C:29:EA:E7:FA

3. What is a port scan?

- A port scan is a technique used to find open, filtered, and closed ports on a host. It is done by sending many packets to ports on a host and analyzing the responses. Typically these ports are in direct sequence, or common protocol ports are chosen.

a. How many port scans were run?

- First is to filter out packets that only knock on the ports (SYN) without finishing the handshake using the filter "tcp.flags.syn == 1 and tcp.flags.ack == 0". Then we go to the "Statistics → Conversation" tab to see how many data burst there are. The answer is 3.

b. What computer initiated the port scan(s)? What were the target computers?

- Since IP addresses can easily be faked, we looked at the physical MAC Address instead just in case. Using the same filter in the previous question, we found that the 3 port scans were by:
  1. **Initiator**: Bob's Workstation .26 (00:0C:29:94:F2:0D) → **Target**: Sarah's Workstation .27 (00:0C:29:81:09:11)
  2. **Initiator**: Sarah's Workstation .27 (00:0C:29:81:09:11) → **Target**: Admin Server .28 (00:0C:29:15:09:D5)
  3. **Initiator**: Sarah's Workstation .27 (00:0C:29:81:09:11) → **Target**: Windows DHCP and FTP server .5 (00:0C:29:EA:E7:FA)

c. What type of port scan(s) did the attacker use (refer to the nmap)?

- Using the same filter "tcp.flags.syn == 1 and tcp.flags.ack == 0", we noticed that "Win" are always equal to 1024, 2048, 3072, or 4096, which is the fingerprint of an Nmap TCP SYN Scan (Stealth Scan)

4. What computer (refer by OS name and last octet of the IP address) is running the telnet service?

- Sarah's Ubuntu .27 is running the telnet service. We can tell because telnet runs on port 23, and TELNET communications are coming from Sarah's computer from port 23. (Ex. SYN-ACK comes from her computer from port 23).

a. Which computer(s) accessed the telnet server?

- Only Bob's Windows XP .26 accessed the telnet server.

b. At what time(s)/date did this access occur?

- The first communication was on 2011-10-07 at 14:12:00.
- The session continued until 14:21:55.

5. What usernames/passwords were used to access the telnet server?

Username: vilkp

Password: password

a. **What did the attacker do, if anything, from the telnet server? Explain why the attacker might have done this.**
    1. **The attacker gained access to Sarah's workstation from Bob's Machine:** The transcript from 192.168.100.26 → 192.168.100.27 TELNET packets shows "Last login… from 192.168.100.26".
    2. **Attacker escalated privileges:** They used the command "sudo nmap…" and entered the correct weak password "password" to run commands with root privileges.
    3. **Scanned the admin server:** They used the command "sudo nmap -sS -O 192.168.100.28" to stealth TCP SYN scan the admin server.
    4. **Scanned the DHCP and FTP Server:** They used the same command to scan the Windows .5 machine.
    5. **Stole the data through FTP:** The attacker started an FTP connection to the Windows .5, using the username "anonymous" and password "yeah@right.com", listed the directory contents, and downloaded a file with the command "get Budget.txt". Finally they typed "quit" and "exit" to close the session.

- This is called pivoting or lateral movement. By compromising Bob's workstation first and using that to gain access to Sarah's workstation and using Sarah's to further gain access to the rest of the data/network, the attacker is able to mask their original IP address (makes them harder to find), move more freely, as well as maybe frame Sarah/Bob for the malicious activity. Additionally, gaining access to trusted internal machines allows them to more easily bypass perimeter firewalls and such.

6. What is the IP address of the attacker?

Most like 192.168.100.26.

- Even though we do not know the actual attacker's IP address, Bob's Windows workstation (.26) is the machine that was first used to take control of Sarah's workstation and perform the other actions from there on (as explained above).

Section 2: Server and Client Network Forensics

1. **What computer is serving as a DHCP server? How do you know?**
   - 192.168.100.5 is the DHCP server, this is because DHCP responds from port UDP 67, and that is the port 192.168.0.5 is communicating on.

   a. **What other services is the DHCP server running? How do you know?**
      - The DHCP server is also running an FTP service, we know because when we filter by what ports 192.168.100.5 has traffic to, it only communicates on UDP 67 and TCP 21, where UDP 67 is DHCP and TCP 21 is FTP.

2. **What computer (refer by OS name and last octet of the IP address) is running a web server?**
   - The webserver is being run on the Linux Ubuntu computer on IP address .28.

   a. **Which computer(s) accessed this web server?**
      - The windows PC on IP address 192.168.100.26 (Bob's) accessed the webserver.

   b. **How do you know a web page was accessed? What was the file name of the web page accessed?**
      - The packet capture shows an HTTP GET request requesting the file /contact.html

   c. **What web browser was the user running?**
      - The user was running on Firefox 5.0 on Windows NT 5.1

   d. **At what time did the access occur?**
      - The original HTTP request occurred at 18:17:50 UTC on 2011-10-07

   e. **What web server application was running? (include version number)**
      - The server was running Apache/2.2.16

3. **What did the 'attacker' do once on the FTP server?**
   - The attacker accessed the FTP server using anonymous access and then used the LIST command to open a directory to see what files were available. They then did a RETR function to download Budget.txt and then closed the session with QUIT.

   a. **How many commands were run on the ftp server?**
      - 8 commands were run on the FTP server: USER, PASS, SYST, PORT, LIST, PORT (a second time), RETR, and QUIT.

   b. **What username/password was used to access the FTP server?**
      - anonymous:yeah@right.com

   c. **From what computer was the FTP server accessed?**
      - The computer was 192.168.100.27 Ubuntu.

   d. **Date and time?**

    - The first request was sent at 18:20:49 UTC on 2011-10-07

e. **What file was downloaded from the ftp server?**
    - The file downloaded was Budget.txt

f. **To which computer was this file downloaded?**
    - The file was downloaded onto 192.168.100.27

4. How technically sophisticated is the attacker? Provide evidence to support your claims.

- The attacker used anonymous access to the FTP server, which seems to be a first approach to check if the function is enabled. This implies it was an opportunistic attack and was not planned out with specific vulnerabilities found in advance. On top of this, when they were able to access the FTP server, they listed out the directories, then downloaded a file and left, which implies that they were doing basic reconnaissance and not doing any kind of more advanced malicious attack.

  Additionally, the attacker relied entirely on pre-existing, poorly configured cleartext services like Telnet on .27 and FTP on .5 rather than establishing their own secure and encrypted command and control channels. Because they didn't attempt to encrypt their traffic, their activity such as used commands and the stolen data (Budget.txt) were completely visible on the network.

  Due to these actions, we can conclude that the attacker is using basic tools to exploit poorly constructed configurations and is not demonstrating any detection, evasion, and encryption, meaning they are not very technically sophisticated.

Appendix A: Sec.1 Images

S1Q1

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

dhcp

No.	Time	Source	Destination	Protocol	Length	Info
3	0.001505	192.168.100.26	192.168.100.5	DHCP	342	DHCP Request - Transaction ID 0x6d2fc7a4
4	0.002168	192.168.100.5	192.168.100.26	DHCP	342	DHCP ACK - Transaction ID 0x6d2fc7a4
5	4.944347	192.168.100.26	192.168.100.5	DHCP	342	DHCP Release - Transaction ID 0xed92b6e
6	7.769856	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0xc2517453
7	7.770829	192.168.100.5	255.255.255.255	DHCP	342	DHCP Offer - Transaction ID 0xc2517453
8	7.772056	0.0.0.0	255.255.255.255	DHCP	347	DHCP Request - Transaction ID 0xc2517453
9	7.802439	192.168.100.5	255.255.255.255	DHCP	342	DHCP ACK - Transaction ID 0xc2517453
28	30.846606	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request - Transaction ID 0x65193a74
29	30.872665	192.168.100.5	255.255.255.255	DHCP	342	DHCP ACK - Transaction ID 0x65193a74
67	44.971935	192.168.100.28	192.168.100.5	DHCP	342	DHCP Release - Transaction ID 0x788b13d
69	45.349401	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x2259a872
70	45.349740	192.168.100.5	255.255.255.255	DHCP	342	DHCP Offer - Transaction ID 0x2259a872
71	45.350496	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request - Transaction ID 0x2259a872
72	45.350800	192.168.100.5	255.255.255.255	DHCP	342	DHCP ACK - Transaction ID 0x2259a872
5215	694.592822	192.168.100.26	192.168.100.5	DHCP	342	DHCP Release - Transaction ID 0x14667ca7
5216	699.343478	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0xc1f9a876
5217	699.343858	192.168.100.5	255.255.255.255	DHCP	342	DHCP Offer - Transaction ID 0xc1f9a876
5218	699.344908	0.0.0.0	255.255.255.255	DHCP	347	DHCP Request - Transaction ID 0xc1f9a876
5219	699.345245	192.168.100.5	255.255.255.255	DHCP	342	DHCP ACK - Transaction ID 0xc1f9a876

```
    Next server IP address: 0.0.0.0
    Relay agent IP address: 0.0.0.0
    Client MAC address: VMware_94:f2:0d (00:0c:29:94:f2:0d)
    Client hardware address padding: 00000000000000000000
    Server host name not given
    Boot file name not given
    Magic cookie: DHCP
  ▾ Option: (53) DHCP Message Type (ACK)
      Length: 1
      DHCP: ACK (5)
  ▾ Option: (58) Renewal Time Value
      Length: 4
      Renewal Time Value: 4 days (345600)
  ▾ Option: (59) Rebinding Time Value
      Length: 4
      Rebinding Time Value: 7 days (604800)
  ▾ Option: (51) IP Address Lease Time
      Length: 4
      IP Address Lease Time: 8 days (691200)
  ▾ Option: (54) DHCP Server Identifier (192.168.100.5)
      Length: 4
      DHCP Server Identifier: 192.168.100.5
  ▾ Option: (1) Subnet Mask (255.255.255.0)
      Length: 4
      Subnet Mask: 255.255.255.0
  ▾ Option: (81) Client Fully Qualified Domain Name
      Length: 3
```

S1Q2abc

- 0.0.0.0 [xp] [www] (Windows)
- 192.168.100.1 [A30605]
- 192.168.100.5 [] (Windows)
- 192.168.100.26 [xp] [xp.] [XP] (Windows)
- 192.168.100.27 [Ubuntu] [Ubuntu.local] (Other)
- 192.168.100.28 [www] [192.168.100.28] (Linux)
- 192.168.100.255
- 224.0.0.22
- 224.0.0.251
- 255.255.255.255
- fe80::20c:29ff:fe15:9d5
- fe80::20c:29ff:fe81:911
- fe80::85c6:f0c3:aa3f:2ac0
- ff02::2
- ff02::16
- ff02::fb
- ff02::1:2
- ff02::1:ff15:9d5
- ff02::1:ff81:911

192.168.100.26 [xp] [xp.] [XP] (Windows)
- IP: 192.168.100.26
- MAC: 000C2994F20D
- NIC Vendor: VMware, Inc.
- MAC Age: 1/21/2003
- Hostname: xp, xp., XP
- OS: Windows
- TTL: 128 (distance: 17)
- Open TCP Ports:
- Sent: 569 packets (32,525 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Received: 402 packets (21,386 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Incoming sessions: 0
- Outgoing sessions: 7
- Host Details

192.168.100.27 [Ubuntu] [Ubuntu.local] (Other)
- IP: 192.168.100.27
- MAC: 000C29810911
  - fe80::20c:29ff:fe81:911 (same MAC address)
- NIC Vendor: VMware, Inc.
- MAC Age: 1/21/2003
- Hostname: Ubuntu, Ubuntu.local
- OS: Other
- TTL: 64 (distance: 5)
- Open TCP Ports: 23 22 37072 55866
- Sent: 2507 packets (117,843 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Received: 2561 packets (107,082 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Incoming sessions: 7
- Outgoing sessions: 9
- Host Details

192.168.100.28 [www] [192.168.100.28] (Linux)
- IP: 192.168.100.28
- MAC: 000C291509D5
  - fe80::20c:29ff:fe15:9d5 (same MAC address)
- NIC Vendor: VMware, Inc.
- MAC Age: 1/21/2003
- Hostname: www, 192.168.100.28
- OS: Linux
- TTL: 64 (distance: 0)
- Open TCP Ports: 23 22 80 (Http)
- Sent: 1030 packets (42,726 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Received: 1048 packets (52,659 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Incoming sessions: 6
- Outgoing sessions: 0
- Host Details

192.168.100.5 [] (Windows)
- IP: 192.168.100.5
- MAC: 000C29EAE7FA
- NIC Vendor: VMware, Inc.
- MAC Age: 1/21/2003
- Hostname:
- OS: Windows
- TTL: 128 (distance: 0)
- Open TCP Ports: 1025 80 445 21 (FtpControl) 1026 1028 1031 135
- Sent: 1049 packets (47,470 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Received: 1071 packets (49,211 Bytes), 0.00% cleartext (0 of 0 Bytes)
- Incoming sessions: 5
- Outgoing sessions: 2
- Host Details

S1Q3a

Ethernet · 4 | IPv4 · 4 | IPv6 | TCP · 2133 | UDP

Address A	Address B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A
192.168.100.27	192.168.100.5	1,018	59 kB	12	2,108	48.29%	1,016	59 kB	2
192.168.100.27	192.168.100.28	1,009	59 kB	10	2,045	49.34%	1,009	59 kB	0
192.168.100.26	192.168.100.27	101	6 kB	9	892	11.32%	101	6 kB	0
192.168.100.26	192.168.100.28	5	310 bytes	11	32	15.63%	5	310 bytes	0

S1Q4 transcript

```
..... ..#..'.....'.....!......Ubuntu 11.04
Ubuntu login: vilkp
Password:
Last login: Fri Oct  7 14:08:11 EDT 2011 from 192.168.100.26 on pts/1
Welcome to Ubuntu 11.04 (GNU/Linux 2.6.38-8-generic i686)

 * Documentation:  https://help.ubuntu.com/

145 packages can be updated.
63 updates are security updates.

vilkp@Ubuntu:~$ sudo nmap -Ss.[D.[K.[D.[KsS -O 192.168.100.28
[sudo] password for vilkp:

Starting Nmap 5.21 ( http://nmap.org ) at 2011-10-07 14:13 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.100.28
Host is up (0.00018s latency).
Not shown: 997 closed ports
PORT   STATE SERVICE
22/tcp open  ssh
23/tcp open  telnet
80/tcp open  http
MAC Address: 00:0C:29:15:09:D5 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.17 - 2.6.31
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.53 seconds
vilkp@Ubuntu:~$ sudo nmap -Ss.[D.[K.[D.[KsS -O 192.168.100.5

Starting Nmap 5.21 ( http://nmap.org ) at 2011-10-07 14:19 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.100.5
Host is up (0.00048s latency).
Not shown: 992 closed ports
PORT    STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
445/tcp  open  microsoft-ds
1025/tcp open  NFS-or-IIS
1026/tcp open  LSA-or-nterm
1028/tcp open  unknown
1031/tcp open  iad2
MAC Address: 00:0C:29:EA:E7:FA (VMware)
Device type: general purpose
Running: Microsoft Windows 2003
OS details: Microsoft Windows Server 2003 SP1 or SP2
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.93 seconds
vilkp@Ubuntu:~$ ftp 192.168.1.5.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K.[D.[K...quit
No command 'quit' found, did you mean:
 Command 'quilt' from package 'quilt' (main)
 Command 'luit' from package 'x11-utils' (main)
 Command 'quot' from package 'quota' (main)
 Command 'quiz' from package 'bsdgames' (universe)
```

```
 Command 'quot' from package 'quota' (main)
 Command 'quiz' from package 'bsdgames' (universe)
 Command 'qgit' from package 'qgit' (universe)
 Command 'qwit' from package 'qwit' (universe)
quit: command not found
vilkp@Ubuntu:~$ ftp 192.168.100.5
Connected to 192.168.100.5.
220 Microsoft FTP Service
Name (192.168.100.5:vilkp): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 Anonymous user logged in.
Remote system type is Windows_NT.
ftp> help
Commands may be abbreviated.  Commands are:

!               debug           mdir            qc              send
$               dir             mget            sendport        site
account         disconnect      mkdir           put             size
append          exit            mls             pwd             status
ascii           form            mode            quit            struct
bell            get             modtime         quote           system
binary          glob            mput            recv            sunique
bye             hash            newer           reget           tenex
case            help            nmap            rstatus         tick
cd              idle            nlist           rhelp           trace
cdup            image           ntrans          rename          type
chmod           lcd             open            reset           user
close           ls              prompt          restart         umask
cr              macdef          passive         rmdir           verbose
delete          mdelete         proxy           runique         ?
ftp> dir
200 PORT command successful.
150 Opening ASCII mode data connection for /bin/ls.
10-06-11  02:49PM          1833 Budget.txt
10-06-11  03:50PM             0 Fiscal.txt
10-06-11  03:51PM             0 GenForms.txt
10-06-11  03:50PM             0 Insurance.txt
226 Transfer complete.
ftp> open Budget.txt
Already connected to 192.168.100.5, use close first.
ftp> get Budget.txt
local: Budget.txt remote: Budget.txt
200 PORT command successful.
150 Opening ASCII mode data connection for Budget.txt(1833 bytes).
226 Transfer complete.
1833 bytes received in 0.00 secs (10655.0 kB/s)
ftp> quit
221
vilkp@Ubuntu:~$ quit
No command 'quit' found, did you mean:
 Command 'quilt' from package 'quilt' (main)
 Command 'luit' from package 'x11-utils' (main)
 Command 'quot' from package 'quota' (main)
 Command 'quiz' from package 'bsdgames' (universe)
 Command 'qgit' from package 'qgit' (universe)
 Command 'qwit' from package 'qwit' (universe)
quit: command not found
vilkp@Ubuntu:~$ exit
logout
```

Budget.txt

```
NCDACS
ADFP Trust Fund
Sample
Project Number:
Contract Number:
Beginning
Balance ADFP Funds Spent Current Balance
211
220 25,000 0 25,000
212 3,000 1,000 2,000
213
204
214 2,000 1,000 1,000
215 500 200 300
207
216 500 200 300
217 2,500 0 2,500
Total Expenditures
Current Balance 33,500 2,400 31,100
Amount of
Match
Cash (C) or In-
Kind (IK)
Cost per unit
and Number of
units (if applicable)
Description of
Expenditures Notes
Example:
Richland County $ 700 IK $10/hr for 70 hours administrative
ABC Conservancy $ 2,000 C N/A survey
Grantee Finance Signature: Date
ADFP Signature: Date
Closing Costs
Legal Fees
Expenditure Categories
Environmental Assessment/Audit
Personnel/Administrative
Travel
Baseline Documentation Report
Budget Report
Reporting Period:
Richland County
ABC Easement
July 1 - September 30
Grantee Name:
Project Name:
Source of
Funding
Instructions: List all ADFP expenditures for this reporting period only. If no expenses have been incurred, please
indicate such. Funds, up to 10%, can be moved within the approved line items without prior approval. Any amount above 10% will
require prior approval of the Budget Manager. No new line items will be allowed without prior approval of the Project Administrator
and the Budget Manager.
Matching Funds Report
Instructions: Please list all matching funds received for this project during this reporting period. For personnel services provide the rate of pay and number of
hours worked. Please attach supporting documentation such as time sheets, copies of checks, invoices, or other billing documents that verify expenses. (See
www.ncadfp.org for more details on documentation.)
ADFP Funds Report
Stewardship Endowment
Survey
Easement Purchase
123-ADF
ABC123
Appraisal
July 1, 2009-June 30, 2010
```